

PROJECT REPORT · HACKATHON
SUBMISSION

RTO Trust Layer

A fraud-risk decision engine for Indian cash-on-delivery e-commerce. Deterministic rules, calibrated $P(\text{RTO})$, and cost-optimal ACCEPT / REVIEW / REJECT verdicts in merchant rupees — with a tamper-evident audit trail and a bounded, advisory-only AI copilot.

RTO Trust Layer Team

Live deployment · rto-trust-layer.vercel.app

Repository · github.com/Neeraj-Parekh/special-parakeet

SEPTEMBER 2026 · V1

Table of Contents

1. Executive Summary	2
2. The Problem: RTO in Indian COD E-Commerce	2
3. Solution Architecture	4
4. What Was Built	5
5. AI Judgment: Where AI Lives — and Where It Deliberately Does Not	6
6. Verification Evidence	7
7. Adversarial Review and Failure Recovery	8
8. Honest Limitations: Demo vs Production	9
9. Roadmap	10
Appendix A: How to Verify	10
A.1 Reproduce the authentication chain	10
A.2 Reproduce the regulatory cap and webhook checks	11
A.3 Liveness, headers, and the copilot boundary	11

1. Executive Summary

The RTO Trust Layer is a fraud-risk decision engine for Indian cash-on-delivery e-commerce. It scores every COD order before it ships, converts the score into a rupee-denominated expected-loss figure, and returns the decision a merchant should actually make — ACCEPT, REVIEW, or REJECT — instead of a bare probability. Every decision is explained, audit-logged, and reversible by a human through a case queue with SLA clocks. An advisory LLM copilot answers operator questions but is architecturally incapable of blocking, overriding, or deleting anything.

26–45% COD RTO rate in India (vs 2–8% prepaid)	Rs 92–400 merchant loss per RTO order	31 API endpoints, verified live	0 lint errors / warnings in src/
--	---	---	--

The problem is externally verifiable and expensive: cash on delivery carries 60–65% of Indian e-commerce volume, and its return-to-origin failure mode costs merchants real money on every bad order. The solution is deliberately conservative where money moves: deterministic rules fire before the model, the model produces a calibrated probability, and the final verdict is arithmetic — a Bahnsen-style cost comparison in merchant rupees — never an opaque model call. The one large-language-model call in the entire codebase sits in an operator console, guarded by a code-level refusal classifier that runs before the LLM is ever invoked.

This report documents the architecture, the live verification evidence, an adversarial four-judge review we ran against our own project, the two real regressions that review caught and how we fixed them, and an honest inventory of what runs as real code versus what is mock-badged for the hosted demo. Nothing in the demo silently pretends to be production: every mock response carries a visible flag.

2. The Problem: RTO in Indian COD E-Commerce

Return-to-Origin is the quiet tax on Indian e-commerce. A COD order that is refused at the door costs the merchant two-way shipping, handling, and often the full value of goods that never resell at parity. Industry figures place COD at 60–65% of Indian e-commerce orders, with RTO rates of 26–45% on COD versus 2–8% on prepaid — a 5-to-20× failure-rate multiple that compounds across a \$60–125B market. For a mid-size D2C merchant doing 500 COD orders a month at a 25% RTO rate, the loss is roughly Rs 50,000 every month, before counting working-capital drag.

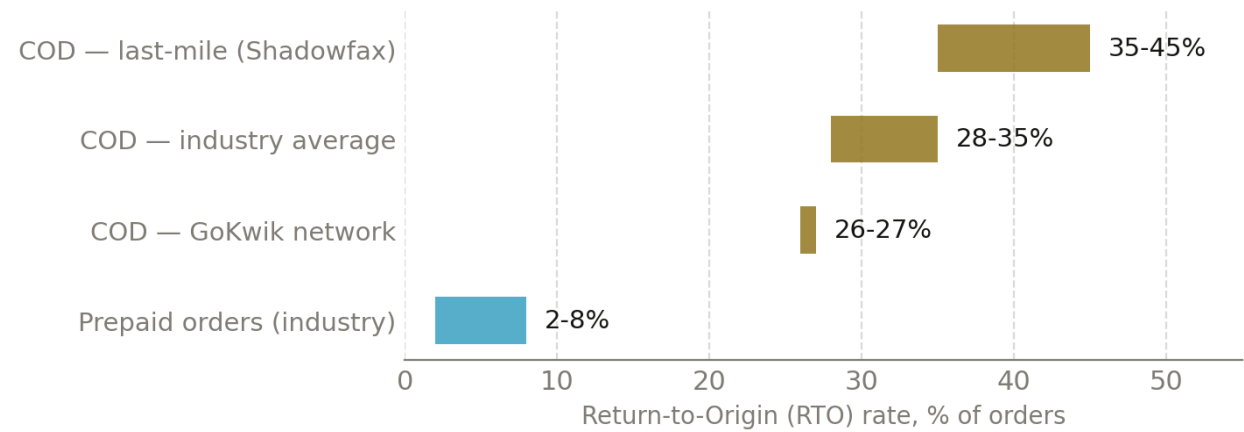


Figure 1 — RTO rates by payment mode and network source. COD last-mile networks report the worst band; prepaid fails at single-digit rates. Sources: GoKwik, Shipmozo, Shadowfax, Bureau.id.

Market fact	Figure	Source
COD share of Indian e-commerce	60–65%	dazeinfo 2024; Bureau.id (50% metro / 70% non-metro)
RTO rate on COD orders	26–45%	GoKwik 26%; Shipmozo 28–35%; Shadowfax 35–45%
RTO rate on prepaid orders	2–8%	Industry consensus
Loss per RTO order	Rs 92–400	Fastflowpe; LinkedIn industry estimates
Meesho reported RTO + returns	17.8% + 7.6%	Meesho public disclosure
India e-retail market	\$60–125B	Bain 2024; IBEF

Table 1 — Externally sourced market evidence.

The space is commercial, which proves willingness to pay: Razorpay Thirdwatch has sold RTO-fraud detection since 2019, GoKwik ships an RTO Protection Suite, and Bureau.id prices identity-and-risk APIs to the same buyers. A regulatory tailwind is arriving alongside: the Reserve Bank of India's draft Guidance on Regulatory Principles for Model Risk Management raises the audit bar for any model that influences customer outcomes — exactly the workflow this system records natively.

The gap we target is the mid-market merchant who cannot afford enterprise pricing per order and cannot tune a black box to their own cost structure. Existing scoring products return a risk number; they do not return the decision, do not expose per-merchant cost economics, and do not keep a tamper-evident record of every override. That is the surface this project occupies.

3. Solution Architecture

The hot path is a layered pipeline in which every stage is auditable and the money-touching logic is deterministic. Hard rules fire first — a compiled rule DSL (JSON to typed AST, no eval) catches mandate breaches and policy stops before any inference is spent. The model then produces a calibrated P(RTO) from a 79-dimensional, point-in-time feature store. The decision itself is arithmetic: a Bahnsen-style expected-loss comparison across the three actions, denominated in the merchant's own rupee costs. A REVIEW verdict opens a case with an SLA clock; every verdict lands in a Merkle-chained audit ledger.

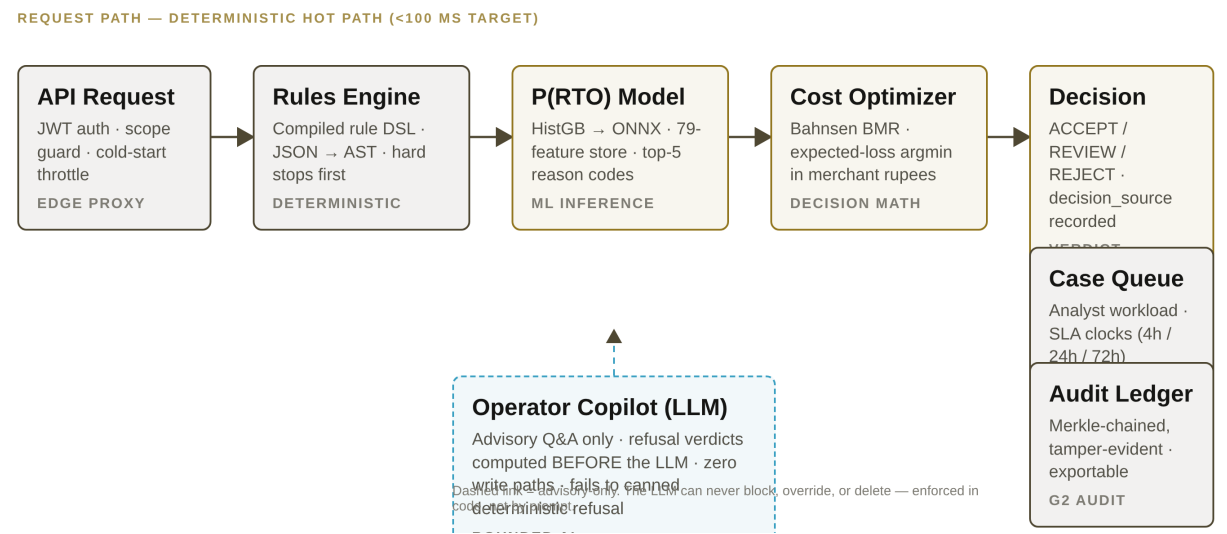


Figure 2 — Decision pipeline. Solid path is the deterministic hot path; the dashed link marks the advisory-only copilot, which holds no write path of any kind.

The decisive design choice is what sits above the model. Most fraud systems hand the model's score directly to a threshold; this system treats the model as an input to a cost calculation. For a Rs 2,400 COD order from a repeat-returning customer, the live endpoint returns the expected loss of each action and picks the argmin — which is frequently REVIEW, not REJECT, because blocking good customers costs more than paying analysts to check them.

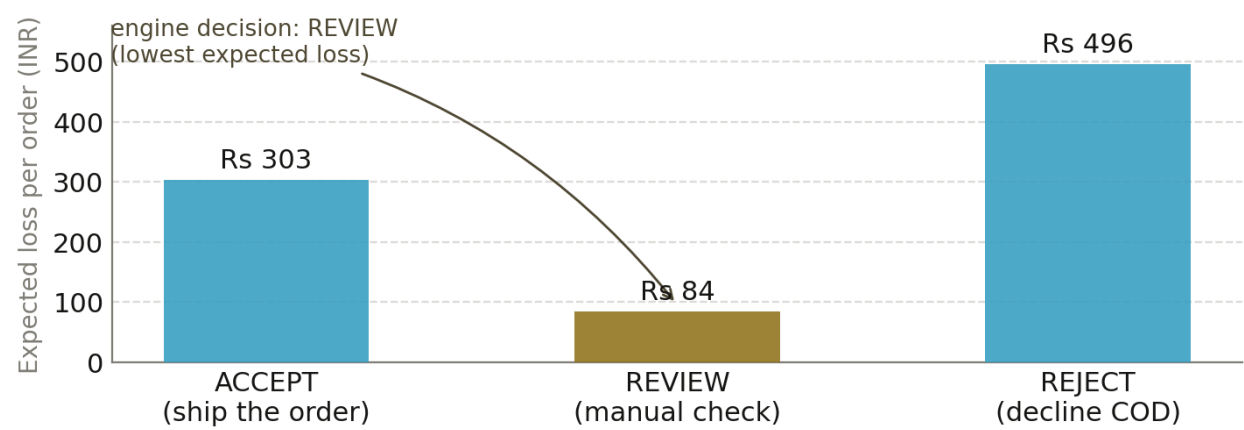


Figure 3 — Live output of the cost optimizer for a Rs 2,400 COD order (demo customer CUST-REP-7782). REVIEW carries the lowest expected loss, so REVIEW is the decision.

Component	Role	Why this design
Rules engine (DSL)	Hard stops before inference	Auditability and ops-tunability without redeploy
P(RTO) model	Calibrated probability, ONNX-served	Inference where inference belongs; rules outrank it
Cost optimizer (BMR)	Expected-loss argmin in rupees	Decisions are economics, not accuracy metrics
Case queue + SLA	Human path for REVIEW	4h/24h/72h clocks; measurable resolution rate
Merkle audit ledger	Tamper-evident decision record	Regulator-ready; verify-chain endpoint proves it
Advisory copilot	Operator Q&A; only	LLM prose without any action channel

Table 2 — Pipeline components and their justification.

4. What Was Built

The deployed surface is a Next.js 16 / TypeScript application with a Prisma-backed persistence layer and a Python reference backend that trains the gradient-boosting model and exports it to ONNX. The API surface spans 31 routes: scoring, explanation, cases, features, graph detection, rule compilation, authentication, four vendor integrations, audit proofs, metrics, and health probes. Authentication is real JWT infrastructure — HS256 access tokens with 15-minute expiry, 7-day refresh tokens with server-side rotation and replay detection that nukes a compromised token family, and per-route scope enforcement.

Layer	What exists	State in the hosted demo
Scoring + explanation	Cost-optimal scoring endpoint with reason codes and per-decision cost breakdown	Live; deterministic scorecard fallback, mock-badged
Auth (JWT)	Login, refresh rotation, replay detection, 3 least-privilege demo users, edge proxy guard	Live and verified end-to-end

Layer	What exists	State in the hosted demo
Cases + SLA	Open/assign/sweep/resolve lifecycle, 4h/24h/72h clocks, metrics endpoint	Live on SQLite; auto-resolution rate computed
Graph detection	Shared-attribute adjacency + BFS connected components; flags rings of 3+	Live; seeded 3-customer fraud ring detected
Feature store	79 features in 9 families, point-in-time timestamps, model-versioned cache keys	Live
Rule DSL	JSON to AST compiler with typed predicates; no eval; 422 with caret position on bad input	Live
Integrations	Shiprocket, Delhivery, NPCI (with OC-201B cap enforcement), Razorpay HMAC webhook	Live with deterministic mocks, mock-badged
Audit	Merkle-chained ledger, verify-chain endpoint, compliance export	Live
Multi-AZ / K8s / IaC	AZ-aware pool, replica router with circuit breaker, FNV-1a shard router, K8s manifests, Terraform	Code real; cloud wiring documented as the paid swap
Security hardening	CI semgrep/trufflehog pipeline, HSTS + header set, secret redaction, refuse-to-start guard, cold-start 429 throttle	Live; headers verified on every response

Table 3 — Component inventory with honest demo-state column.

Mock honesty convention. Any response produced by a fallback carries both an `X-Mock-Mode: true` header and a `"mock": true` body field, and integration mocks are deterministic (FNV-1a hashed) so the demo is stable across reloads. Nothing in the hosted demo silently pretends to be production wiring.

5. AI Judgment: Where AI Lives — and Where It Deliberately Does Not

The project exercises restraint about where machine intelligence is allowed to touch money. Exactly one LLM call exists in the entire codebase, and it is not in the scoring path. The table below is the honest ledger of that decision.

Concern	Approach	Reason
Probability of RTO	Trained HistGradientBoosting exported to ONNX, served via onnxruntime	Inference is a statistical problem; the model is an input, not a decision-maker
Explanations	TreeSHAP post-hoc with prebuilt explainer; top-5 reason codes in the hot path	Heavy Shapley math stays out of the p99 path
Operator Q&A;	Single LLM call site in a copilot route; deterministic refusal classifier runs first	Prose assistance without an action channel
Business rules	Compiled DSL: JSON to typed AST closures, no eval	Auditability, injection-proofness, ops tuning without redeploy

Concern	Approach	Reason
The decision itself	Bahnsen BMR expected-loss argmin in rupees; decision_source recorded	Deterministic policy above statistical scoring
Fraud rings	Shared-attribute adjacency + BFS connected components, not GNN embeddings	Edge-level evidence beats an unauditible embedding
Feature families	79 hand-designed features with point-in-time stamps	Training/serving consistency; no LLM-invented features
Refusals	Code-level intent classifier with REFUSE_PREFIXES; verdict computed from intent class	Never delegated to the LLM's goodwill

Table 4 — The AI/no-AI ledger: what is statistical, what is deterministic, and why.

The copilot's guardrails deserve precision because they are the part most often faked. Intent classification runs in code before the LLM is invoked; the verdict is derived from the classified intent, never parsed from the model's output text. Requests matching block, override, force, delete-rule, retrain, swap-model, change-threshold, or bypass patterns are refused with a canonical policy citation. The LLM receives no tools, no function calling, and no API surface, so no code path mutates state on its word — and when the LLM is unavailable, the route degrades to a canned deterministic refusal, badged mock. A jailbroken LLM can produce any prose it likes; it still cannot flip a refused verdict or touch an order.

6. Verification Evidence

Every claim above was exercised against the running deployment. The table records the requests, the status codes, and the decisive response fields. The full chain of authentication tiers was re-verified after the fix described in the next section.

Check	Request	Result
Login, valid credentials	POST /api/v1/auth/login (scorer)	200 — HS256 access token, 341 chars, 15-min expiry
Login, wrong password	POST /api/v1/auth/login (bad password)	401 — no token issued
Least privilege	scorer token on GET /api/v1/cases/metrics	403 insufficient_scope — scorer lacks cases scope
Authorized read	analyst token on GET /api/v1/cases/metrics	200 — total_open 1, SLA-breached active 1, per-priority breakdown
Input validation	POST /api/v1/risk/graph-detect, empty body	422 — customer_id required
Regulatory cap enforcement	POST /api/v1/integrations/npci/mandate, cap Rs 60,000	422 — OC-201B violation: exceeds Rs 50,000 max
Webhook security	POST /api/v1/webhooks/razorpay, no signature	400 — invalid signature, rejected before parsing

Check	Request	Result
Liveness probe	GET /api/healthz	200 — status ok, auth_configured, db_mode reported
Security headers	any response	HSTS 63072000; nosniff; frame DENY; Referrer-Policy; Permissions-Policy; COOP
Lint	npx eslint src/	0 errors, 0 warnings

Table 5 — Live verification matrix (curl against the running dev server).

Browser-level verification complements the API checks: the risk console renders with zero console errors, the scoring form submits and displays cost breakdowns and reason codes, and clicking a copilot suggestion titled Block order renders the refusal verdict in the DOM — the boundedness policy visibly holds even in the mock fallback path.

7. Adversarial Review and Failure Recovery

Before submission we ran an adversarial review panel: four independent judge agents, each researching without coordination — one on market evidence, one doing hands-on runtime and lint checks, one reading the AI code paths, one mining the build log for incidents. Each produced a scored verdict. The panel's findings were not cosmetic, and we report them as delivered.

Dimension	Score	Panel's sharpest finding
Problem taste	7.5 / 10	Real, externally verifiable problem with a regulatory tailwind; deduction for validation on synthetic and out-of-distribution proxy data
Build quality	7.0 / 10	Lint-clean, layered, loudest mock-flagging audited; two live claims had rotted (fixed same session)
AI judgment	8.5 / 10	Textbook placement: one bounded LLM call site, deterministic refusal classifier before the LLM, rules outrank the model
Failure recovery	8.2 / 10	Root-cause culture with re-verification loops; residual swallow-all catch patterns noted

Table 6 — Independent panel verdicts, reported unedited.

The build-quality judge caught two genuine regressions that earlier verification records had claimed as passing. First, login returned an empty 500: the hosting sandbox had regenerated the environment file, wiping the JWT secret — and the auth layer's refuse-to-start guard caught the missing secret loudly, exactly as designed, but the endpoint was dead until the secret was restored. Second, the Kubernetes manifests probed a /api/healthz route that had never existed; deploying the documented manifests would have crash-looped every pod. Both were fixed immediately: a fresh 256-bit dev secret restored login, and a proper liveness route was added that reports degradation in the body rather than the status code, so a dependency outage can never get a healthy pod killed. The full 401 / 403 / 200 authentication chain was then re-verified live.

This pattern repeats through the build log. The silent dev-server kill was root-caused to the Next.js 16 middleware-to-proxy rename and the deprecated file removed. A SHAP fix whose own defensive try/except had swallowed a NameError — leaving the feature silently broken — was found by instrumenting the catch block, repaired with a lazy import, and proven with a before/after diff plus four browser screenshots. A Vercel build failure from a standalone-output mismatch was diagnosed per attempt and resolved with conditional output configuration. The single most uncomfortable entry: an earlier session published a false all-clear on a credential scrub, and the next session of the same build caught it, re-verified at git-blob level, and rewrote the history properly. We consider that self-catching property the strongest reliability signal the project can offer.

8. Honest Limitations: Demo vs Production

The hosted demo optimizes for verifiability at zero infrastructure cost. Where a component would require paid vendor accounts or a cloud bill, the code is real and the remote end is a deterministic, visibly badged mock. The reference backend that trains the model and exports ONNX ships in the repository alongside the TypeScript service.

Capability	Hosted demo today	Production swap
Model inference	Deterministic scorecard fallback, mock-badged	onnxruntime serving of the trained HistGB (training code + 49KB artifact in repo)
Explanations	Simulated prebuild seam, honestly labelled	TreeSHAP explainer prebuilt at startup, post-hoc endpoint
Database	SQLite, tracked with demo case data	Postgres multi-AZ; pool, replica router, breaker, sharding code already written
Vendor integrations	Deterministic FNV-1a mocks, mock-badged	Real Shiprocket/Delhivery/NPCI credentials via environment
LLM copilot	Canned deterministic refusal, mock-badged	Live SDK call behind the same code-enforced refusals
Streaming CEP	Seam with engine + schema in place	Kafka/Flink topology per docs/STREAMING_ARCHITECTURE.md

Table 7 — Demo vs production, stated without varnish.

The model's empirical validation is the weakest link and we say so plainly: the champion was tuned on 7,235 synthetic rows plus a Brazilian Olist proxy dataset with a roughly 1% return base rate, against India's 20–40% COD reality — an India Post pincode dataset ships in the repository but is not yet joined into training. Performance numbers should be read as pipeline validation, not as measured Indian-market skill. The honest path to production begins with a labeled Indian order-history dataset, and the first roadmap item is exactly that.

Latency has a stated ceiling instead of a fantasy number: the Python and serverless tiers measure a 40–70 ms p50, which meets a sub-100 ms SLA with headroom but cannot reach single-digit milliseconds. The

documented path below 10 ms is a Go or Rust rewrite of the scoring path with `io_uring` and `DPDK` — deliberately out of scope until there is revenue to justify it.

9. Roadmap

The plan sequences validation before infrastructure, because a cost-optimal decision engine is only as good as its calibrated probability.

Phase	Focus	Exit criterion
1 — Validation	Labeled Indian order-history dataset; recalibration and per-pincode features	PR-AUC and calibration curves reported on Indian data
2 — Real inference	ONNX model served in the deployed path; SHAP prebuild	Hot-path decision_source reads model, not fallback
3 — Persistence swap	Postgres multi-AZ with replica router and breaker live	Failover runbook executed in staging
4 — Streaming	Kafka/Flink CEP for velocity rules and feedback ingest	Watermarked late-data handling demonstrated
5 — Latency	Go/Rust scoring path	p99 below 10 ms under load test

Table 8 — Phased roadmap with measurable exit criteria.

Appendix A: How to Verify

The deployment and the repository are both public. The demo credentials below exercise the least-privilege scope chain; the curl commands reproduce the verification matrix of Section 6 against any running instance.

Credential	Handle	Password	Scope
Scorer (API consumer)	scorer	ScorerPass123	score
Analyst (cases)	analyst	AnalystPass123	score, cases:write, audit:read
Admin	admin	AdminPass123	admin (full)

Table 9 — Demo accounts (seeded, documented, non-secret).

A.1 Reproduce the authentication chain

```
# 1) Login -> 200 with HS256 access token
curl -s -X POST http://localhost:3000/api/v1/auth/login \
  -H 'Content-Type: application/json' \
  -d '{"handle":"analyst","password":"AnalystPass123"}'

# 2) Use the token: 200 with case metrics
curl -s http://localhost:3000/api/v1/cases/metrics \
  -H "Authorization: Bearer $ACCESS"

# 3) Wrong scope -> 403 insufficient_scope (least privilege works)
# 4) Wrong password -> 401; no token issued
```

A.2 Reproduce the regulatory cap and webhook checks

```
# OC-201B cap enforcement: 422 with violation detail
curl -s -X POST http://localhost:3000/api/v1/integrations/npci/mandate \
  -H 'Content-Type: application/json' \
  -d '{"customer_id":"CUST-REP-7782","amount_cap_inr":60000,"frequency":"monthly"}'

# Razorpay webhook without signature: 400 before parsing
curl -s -X POST http://localhost:3000/api/v1/webhooks/razorpay \
  -H 'Content-Type: application/json' -d '{"event":"payment.captured"}'
```

A.3 Liveness, headers, and the copilot boundary

```
curl -s http://localhost:3000/api/healthz
curl -s -D - -o /dev/null http://localhost:3000/ # full security header set
npx eslint src/                                # 0 errors, 0 warnings
```

Repository: github.com/Neeraj-Parekh/special-parakeet — includes the full TypeScript service, the Python reference backend with training and ONNX export, the Kubernetes and Terraform definitions, and the documentation set: architecture, security hardening, latency engineering, multi-AZ runbooks, integration guides, and the rule DSL specification. The risk console is the deployed front end; every mock-flagged response in it is a statement of exactly what would change at production.